

Ciberseguridad — Por qué necesitamos revisión humana especializada

Autor: David Cabezas (dev full-stack junior)

Destinatario: José (decisión de hiring / scope security)

Fecha: 2026-04-23

Contexto: Plataforma AMS (Mageam) con integración SAP PM, data industrial crítica (Goldfields).

TL;DR

Hoy corrí un audit defensivo con Claude y **encontramos 5 vulnerabilidades CRÍTICO/ALTO que ya parcheé**. Pero una IA tiene techos duros en seguridad: **no puede atacar, no puede explotar cadenas de bugs, no tiene contexto del atacante real**. Sin un rol de seguridad humano (interno o consultor externo), quedamos expuestos a los mismos tres escenarios que llevan a incidentes en la industria minera.

Qué hizo Claude en el audit de hoy

- **Static analysis de código:** grep de patrones peligrosos (IDOR sin `assert_plant`, inyección HTML sin escape, `hmac` faltante).
- **Detección de endpoints nuevos sin auth:** enumeró los 6 endpoints que agregué hoy y verificó que tuvieran `require_role` o `get_current_user`.
- **Fixes automáticos:** parches IDOR + XSS + timing attack en 4 archivos, commiteados en minutos.
- **OWASP Top 10 checklist:** revisó inyección SQL, XSS, CSRF, mass assignment, path traversal, SSRF, secretos hardcoded.

Vulnerabilidades encontradas y arregladas hoy:

- IDOR crítico en FMECA (usuarios podían leer recursos de otras plantas).
 - IDOR en Cancel WR (supervisor podía cancelar avisos de otra planta).
 - AuthZ faltante en export SAP-IW22 y from-RCA.
 - XSS en ExecutiveView (respuestas AI sin escape antes de parse markdown).
 - Timing attack en comparación de DEPLOY_SECRET.
-

Qué Claude NO puede hacer — 4 huecos que obligan a un rol humano

1. Explotación activa (pentest real)

- **Limitación IA:** No puedo **atacar** la plataforma. Sólo leo código. Un pentester humano corre Burp Suite, fuzzing de parámetros, prueba cadenas de bugs (SQLi + SSRF + lectura de archivos), valida

que los fixes realmente bloqueen la explotación.

- **Ejemplo concreto:** Arreglé el IDOR poniendo `_assert_plant_access`. ¿Pero funciona si alguien pasa `plant_id=null`? ¿Y si lo pasa URL-encoded dos veces? ¿Qué pasa si el JWT no trae `plant_id`? Un pentester prueba **las cinco variaciones** en 10 min. Yo sólo puedo prever las obvias.
- **Qué hace un rol humano:** pentest trimestral, bug bounty interno, red team exercises.

2. Entender al atacante real del contexto minero

- **Limitación IA:** No conozco las amenazas específicas del sector. Una minera puede ser objetivo de:
 - **Ransomware industrial** (Conti, LockBit apuntaron a mineras 2022-2024).
 - **Sabotaje OT/IT** (competidores, grupos activistas ambientales).
 - **Insider threats** (contratistas con acceso temporal que llevan data).
 - **Espionaje industrial** (estrategias de mantenimiento son IP valiosa).
- **Ejemplo concreto:** La integración SAP-IW22 que agregué hoy exporta datos de OTs + equipos + costos en CSV. **¿Qué data sensible sale? ¿Quién puede descargarlo?** Le puse `require_role(admin/manager/planner)` pero no sé si en el contexto de Goldfields un **planner externo contratista** debería poder exportar toda la estrategia de mantenimiento.
- **Qué hace un rol humano:** threat modeling con contexto del cliente, clasificación de data (PII/IP/operacional/pública), diseño de controles por rol real de Goldfields.

3. Operaciones de seguridad en vivo (SecOps)

- **Limitación IA:** Yo reviso código una vez. **No monitoreo logs 24/7**. No detecto cuando alguien está probando credenciales cada 3 segundos, cuando el endpoint de login recibe 10k requests desde una IP sospechosa, cuando un usuario legítimo de repente descarga 50 OTs a las 3am.
- **Ejemplo concreto:** Hoy bajamos el rate-limit a 600/min por un bug de UX. **Eso abrió la puerta a brute-force de login** (auth_limit sube a 20r/m via nginx, pero el app-level permite 600). Un SOC detectaría el pico; Claude no puede.
- **Qué hace un rol humano:** SIEM (Splunk, Datadog), alertas activas, respuesta a incidentes, rotación de secretos, forense post-breach.

4. Compliance y auditoría formal

- **Limitación IA:** No firmo reportes, no certifico. Mineras grandes (Goldfields, Codelco, BHP) exigen:
 - **ISO 27001** certificación del proveedor SaaS.
 - **SOC 2 Type II** (auditoría externa anual).
 - **Chile Ley 21.663** (protección de datos personales, vigente 2024).
 - **Data Processing Agreement** (DPA) con cliente.
 - **Ejemplo concreto:** Goldfields probablemente ya pidió (o pedirá) evidencia de cómo manejamos data. Yo escribí código que guarda firmas de supervisor, fotos de fallas, PINs truncados. **¿Eso pasa una auditoría ISO 27001? No tengo idea — no soy auditor.**
 - **Qué hace un rol humano:** prepara documentación (políticas, procedimientos, DPA), gestiona auditorías externas, coordina con el cliente cuando piden evidencia de controles.
-

Lo que Claude + David logra (y lo que deja expuesto)

Capa	Cubierto hoy	Hueco si no hay seguridad humana
Code review estático	parches IDOR/XSS/timing	Ataques combinados (SQL+SSRF)
Configuración infra (nginx, docker)	headers, CORS, HSTS	Hardening VPS (ssh-keys, fail2ban, updates OS)
Autenticación	bcrypt, JWT 32+ chars, MFA	Gestión de secretos (rotación, vault)
Secretos en repo	.gitignore validado	Secrets scanning CI
Pentest real	NO	Sólo humano
SOC / monitoreo	NO	Sólo humano
Compliance	NO	Sólo humano
Threat modeling cliente-específico	Parcial	Sólo humano

Vectores reales a los que estamos expuestos HOY

1. **Tabnabbing + phishing SAP:** usuarios con sesión abierta en mageam.com + mismo browser en Outlook corporativo = crafted link puede robar token si no hay SameSite strict + CSRF.
2. **Supply chain (dependencias npm/pypi):** agregué 2 librerías hoy. Ninguna verificación de si están firmadas, auditadas o comprometidas (caso event-stream 2018, ua-parser-js 2021).
3. **Insider threat — contratista planner:** hoy un planner puede exportar IW22 de toda la planta. Si se va a la competencia, se lleva la estrategia de mantenimiento en un CSV.
4. **VPS sin hardening:** deployamos en un VPS root@IP directo. ¿SSH con keys? ¿Fail2ban? ¿Updates automáticos del OS? No lo verifiqué.
5. **Logs sensibles:** los logs del backend muestran WebSocket path con plant_id + client_id. Si alguien accede a los logs, tiene información de planta + usuarios conectados.

Propuesta de scope Seguridad

Mínimo viable (externo, una vez):

1. **Pentest tercerizado** — 40h una vez antes del go-live con Goldfields (~\$3-5k USD Chile).
2. **Revisión de compliance** — abogado/consultor Ley 21.663 (~8h consultoría).
3. **Hardening VPS** — SysAdmin 10h (ssh-keys, fail2ban, auto-updates, backups cifrados, cert Let's Encrypt rotativo).

Recurrente (interno part-time, 10h/semana):

1. Monitoreo básico de logs (Grafana Loki + alertas a Slack).
2. Actualización mensual de dependencias (pip-audit, npm audit).
3. Revisión post-deploy de cada feature que toque auth/permissions/data export.
4. Respuesta a incidentes (plan escrito de qué hacer si se filtra un token).

Ideal (si crecen los clientes):

- Certificación ISO 27001 (6-12 meses, ~\$15k USD).
 - SOC 2 Type II (anual, ~\$30k USD).
 - Bug bounty privado (HackerOne / Intigriti).
-

Conclusión para José

Hoy arreglé 5 vulnerabilidades reales. Eso valida que el audit sirve. Pero **lo que no vemos es lo que mata**. Una IA cubre el 70% del security review de código; el 30% restante (pentest real, SecOps 24/7, compliance, threat modeling del sector) exige humanos especializados.

Con Goldfields entrando a producción, **el costo de una brecha es muy superior al costo de un consultor de seguridad tercerizado 40h**. Mi recomendación: pentest externo antes del go-live + hardening del VPS + plan básico de respuesta a incidentes. Eso es el piso mínimo defendible ante el cliente.